

Customer-Facing Compliance Report

Framework: Cloud Security Alliance Cloud Controls Matrix (CCM) v4

Primary audience: Cloud service providers preparing CSA STAR submissions (self-assessment, STAR Level 1) or CSA STAR Certification / Attestation (Level 2), and cloud customers using CCM as a control reference.

CSW positioning: Infrastructure and Virtualization Security (IVS), Data Security and Privacy Lifecycle (DSP), and Threat and Vulnerability Management (TVM) evidence at the cloud workload layer.

Framework Version Note

References CCM v4. The CCM is updated periodically; validate the version applicable to the customer's STAR (Security, Trust, Assurance, and Risk) submission. CCM domain abbreviations used here (e.g. IVS Infrastructure & Virtualization Security, DSP Data Security and Privacy Lifecycle Management, TVM Threat & Vulnerability Management) are stable in v4.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The technical runbook (CSW-CSA-CCM-Technical-Runbook.md) in this folder contains the deeper engineering detail.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW "certifies" compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer's compliance team, and the customer's assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does not replace the customer's governance, policy, or assessor judgement, and this report is not a control attestation.

Suggested CSW Scope Pattern

“

CSA-CCM

??? Cloud-Workloads (Customer-Tenants and Shared-Infrastructure)

??? Tenant-Boundaries

??? Data-Protection-Scope

??? Management-Plane

This scope pattern should be validated with the customer's architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- ? IVS - Infrastructure and Virtualization Security (segmentation, tenant boundary)
- ? DSP - Data Security and Privacy Lifecycle (data-flow visibility, segmentation)
- ? TVM - Threat and Vulnerability Management (reachability-weighted CVE)
- ? LOG - Logging and Monitoring (workload telemetry as one log source)
- ? SEF - Security Incident Management, E-Discovery, and Cloud Forensics (forensic input)

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- ? AAA - Audit Assurance and Compliance (governance)
- ? BCR - Business Continuity Management and Operational Resilience
- ? CCC - Change Control and Configuration Management beyond CSW workspace
- ? DCS - Datacenter Security (physical)
- ? GRC - Governance, Risk Management, and Compliance
- ? HRS - Human Resources
- ? IAM - Identity and Access Management lifecycle
- ? STA - Supply Chain Management beyond CSW egress visibility

Framework Topic ? CSW Capability Map

Framework topic	CSW capability	Evidence artifact
IVS - Infrastructure and Virtualization Security	Policy workspace + tenant-boundary deny enforcement	Workspace snapshot + cross-tenant violation log
DSP - Data Security (segmentation)	Workload-to-workload allowlist between data-protection scopes	Workspace snapshot + observed-vs-approved flow comparison
TVM - Threat and Vulnerability Management	Reachability-weighted CVE on cloud workloads	Prioritised remediation list with compensating-control register
LOG - Logging and Monitoring	Continuous flow + process telemetry; alerts	Alert and anomaly log scoped to CSA-CCM
SEF - Incident Management / Forensics	Forensic flow + process search	Investigation pack with timeline and tenant-impact scoping

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
Cloud workload inventory across tenants	Workloads grouped by tenant / service offering		

Inventory + scope membership export filtered by tenant and service_offering | Monthly |
| Tenant separation evidence | Cross-tenant deny enforcement and violation log | Policy
workspace export + policy analysis output | Continuous; reviewed quarterly |
| Vulnerability + reachability | CVE list weighted by reach into tenant data scopes |
Vulnerability report scoped to CSA-CCM | Monthly |
| Monitoring evidence | Continuous flow + process telemetry; alerts | Alert and anomaly log
export | Continuous |
| Forensic sample | Workload-level timeline for one representative incident | Flow + process
search | Per incident |

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. tenant, prototype, isa_level, np, cui, ephi').
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not replace CSA STAR submission / attestation, CSP organisational and physical controls, identity lifecycle (IAM), key management (KMS), backup and DR, portability and interoperability, or shared-responsibility model decisions.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.